ACTIVE DIRECTORY

Infrastructure Requirements & Design Document

Savora Hospitality Group - 4 Restaurant Brands, 12 Branches

Item	Detail
Document title	AD Requirements, Design and Implementation Plan
Company (fictional)	Savora Hospitality Group
Prepared by	jhayarzuniga, IT Engineer
Requested by	Group Chairman / CEO
Version / Date	1.0 - October 16, 2026
Purpose	Cybersecurity portfolio project (lab build on virtual machines)
Classification	Internal - lab / training use only

Contents

Section	Title	Covers
1	Introduction	Purpose, background, objectives, scope, assumptions
2	Business Requirements	BR-01 to BR-10
3	Organization Profile	Brands, branches, roles, lab population
4	Active Directory Design	Forest model, naming, OUs, groups, delegation, tiering, sites, DNS/DHCP/FSMO
5	Architecture Diagrams	Logical AD design, VM lab topology, Kerberos flow
6	Technical Requirements (Lab Build)	Host, VMs, software, network
7	Security Requirements	Password policy, Kerberos requirements, hardening, auditing, attack/defense lab
8	Group Policy Plan	GPO list and links
9	File Server and Access Design	Shares and AGDLP permissions
10	Implementation Plan	Phases 0-14 and build scripts
11	Test and Validation Plan	TC-01 to TC-12
12	Portfolio Deliverables	Evidence checklist
13	Risks and Assumptions	Risk register
14	Approval	Sign-off
A / B	Appendices	Command cheat sheet, glossary

1. Introduction

1.1 Purpose

This document defines the business and technical requirements for a centralized identity and access platform built on Microsoft Active Directory Domain Services (AD DS) for Savora Hospitality Group. It also gives the design, the build order, the security baseline (with emphasis on Kerberos) and the tests needed to prove the system works.

1.2 Background

Savora Hospitality Group is a company group that owns four restaurant brands. Each brand has three branches and its own management team. At present every branch manages its own PCs and accounts, which causes inconsistent security, no central audit trail and slow onboarding. The Chairman has asked the IT Engineer to build one company-wide directory that centralizes authentication while still letting each brand run its own day-to-day administration.

1.3 Objectives

- Provide one identity for every employee across all 4 brands and 12 branches.
- Give each brand management **delegated control** over only its own users and computers.
- Keep security-critical control (domain controllers, privileged accounts, policy) with HQ IT.
- Standardize security through Group Policy and a documented hardening baseline.
- Understand, configure, monitor and attack-test **Kerberos** in a safe lab to build real cybersecurity skill.
- Produce evidence (screenshots, scripts, test results) suitable for a professional portfolio.

1.4 Scope

In scope	Out of scope
AD DS forest and domain design DNS and DHCP services OU, group, user and computer design Delegation of administration Group Policy and security baseline File server and permissions (AGDLP) Kerberos configuration, auditing, attack/defense lab Backup and restore of AD Optional forest trust to a second forest	Real production deployment Cloud identity (Entra ID / hybrid) - future phase Exchange / email POS application software itself Physical WAN links, VPN hardware Real employee data (all names are fictional)

1.5 Assumptions

- The build is done on virtual machines on a single host using evaluation licenses.
- Branches are simulated as logical AD Sites; no physical WAN is built.
- All names, users, and addresses are fictional and safe to publish in a portfolio.

2. Business Requirements

Each requirement has an ID so that it can be traced to a design decision and a test case in Section 11.

ID	Requirement	Priority
BR-01	One central directory authenticating all employees of the 4 brands and 12 branches.	Must
BR-02	Each brand has its own management and must administer its own users and PCs independently of other brands.	Must
BR-03	HQ IT retains exclusive control of domain controllers, privileged accounts and security policy.	Must
BR-04	Single sign-on to file shares and internal resources using Kerberos.	Must
BR-05	A standard security baseline (password, lockout, hardening) enforced to all computers.	Must
BR-06	Audit trail for sign-ins, privilege use and changes to users and groups.	Must
BR-07	No single point of failure: at least two domain controllers with replication.	Must
BR-08	New hire onboarding and leaver offboarding done in a repeatable, scripted way.	Should
BR-09	Ability to add a new brand or connect to another company's forest (acquisition / partner) later.	Should
BR-10	Documented backup and recovery procedure for AD.	Should

3. Organization Profile

3.1 Brands and Branches

Brand	Code	Branches (code)	Brand management
Casa Fuego (Mexican)	CF	Makati (MKT), BGC (BGC), Quezon City (QC)	Brand GM + Brand IT Admin
Sakura Bay (Japanese)	SB	Ortigas (ORT), Alabang (ALB), Cebu (CEB)	Brand GM + Brand IT Admin
Trattoria Bella (Italian)	TB	Greenhills (GRH), Eastwood (EST), Davao (DVO)	Brand GM + Brand IT Admin
Golden Wok (Chinese)	GW	Binondo (BIN), Pasay (PSY), Baguio (BAG)	Brand GM + Brand IT Admin

3.2 HQ Departments and Branch Roles

- **HQ-Corporate:** Chairman/CEO, Finance, HR, Purchasing, Group IT (Tier 0 administrators).
- **Each brand:** General Manager (GM) and Brand IT Admin (delegated administrator).
- **Each branch:** Branch Manager, Supervisor, Cashier / POS operator, Kitchen staff, Service staff, Inventory clerk.

3.3 Lab Population

To keep the lab realistic but light, the lab uses about 60 sample users (about 5 per branch plus HQ staff) created by a CSV import script, and two Windows client VMs that represent staff PCs for different brands.

4. Active Directory Design

4.1 Forest and Domain Model

Three models were considered. The recommended design is a single forest with a single domain, using Organizational Units (OUs) and delegation to give each brand its own management.

Option	Advantages	Disadvantages	Decision
Single forest, single domain + OUs	Simple, cheap, easy Kerberos, delegation per OU is enough for brand autonomy	All brands share one security boundary at forest level	Selected
Single forest, child domain per brand	Separate password policies and admin groups per domain	More DCs, more complexity; a domain is NOT a security boundary (the forest is)	Rejected
Separate forest per brand	Strongest isolation	High cost; needs trusts; poor fit because brands are one company	Rejected (used only for acquisition / partner trust lab)

> **Key concept:** In AD the **forest** is the security boundary, not the domain. Because all four brands belong to one company that trusts its own staff, one domain with strong OU delegation is the correct and most maintainable choice.

4.2 Naming Standards

Object	Standard	Example
Forest / domain DNS name	corp.<company>.com (a subdomain you control; avoid .local in real life)	corp.savorahg.com
NetBIOS name	Short, uppercase	SAVORA
Servers	Role + number	DC01, DC02, FS01
Workstations / POS	BrandCode-BranchCode-Type+Number	CF-MKT-POS01, SB-ORT-PC02
Standard user	First initial + last name	msantos
Admin account	adm- prefix, separate from daily account	adm-msantos
Service account	svc- prefix (or gMSA)	svc-backup
Global group (people)	GG-Brand-[Branch]-Role	GG-CF-MKT-Staff, GG-CF-Managers
Domain local group (permissions)	DL-Resource-Right	DL-Share-CasaFuego-RW
GPO	Scope-Purpose	WKS-Baseline, POS-Lockdown

4.3 OU Structure

The OU tree mirrors the business: HQ, then brands, then branches. Each branch OU contains Users, Computers and Groups sub-OUs. Figure 1 shows this visually.

Script 1 - Create the OU tree (OU names contain no spaces)

```
$base = "DC=corp,DC=savorahg,DC=com"

# Top-level OUs
foreach ($ou in "_Admin","HQ-Corporate","Brands","ServiceAccounts","Quarantine") {
    New-ADOrganizationalUnit -Name $ou -Path $base -ProtectedFromAccidentalDeletion $true
}
```

```
foreach ($sub in "Users","Computers","Groups","Servers") {
    New-ADOrganizationalUnit -Name $sub -Path "OU=HQ-Corporate,$base"
}
foreach ($sub in "Tier0","Tier1","Tier2","Groups") {
    New-ADOrganizationalUnit -Name $sub -Path "OU=_Admin,$base"
}

# Brands and branches (OU names have no spaces)
$brands = @{
  CasaFuego      = @{ Code="CF"; Branches=@{ Makati="MKT"; BGC="BGC"; QuezonCity="QC" } }
  SakuraBay      = @{ Code="SB"; Branches=@{ Ortigas="ORT"; Alabang="ALB"; Cebu="CEB" } }
  TrattoriaBella = @{ Code="TB"; Branches=@{ Greenhills="GRH"; Eastwood="EST"; Davao="DVO" } }
  GoldenWok      = @{ Code="GW"; Branches=@{ Binondo="BIN"; Pasay="PSY"; Baguio="BAG" } }
}

foreach ($b in $brands.Keys) {
    $brandDN = "OU=$b,OU=Brands,$base"
    New-ADOrganizationalUnit -Name $b -Path "OU=Brands,$base"
    New-ADOrganizationalUnit -Name "Management" -Path $brandDN
    foreach ($br in $brands[$b].Branches.Keys) {
        New-ADOrganizationalUnit -Name $br -Path $brandDN
        foreach ($sub in "Users","Computers","Groups") {
            New-ADOrganizationalUnit -Name $sub -Path "OU=$br,$brandDN"
        }
    }
}
```

4.4 Group Strategy (AGDLP)

Permissions follow the AGDLP model: Accounts go into Global groups, global groups go into Domain Local groups, and domain local groups receive Permissions. Nobody is ever given permission directly.

Group	Type	Members	Purpose
GG-<Brand>-<Branch>-Staff	Global	All staff of that branch	Branch-level access
GG-<Brand>-Managers	Global	All branch managers of the brand	Brand management resources
GG-<Brand>-GM	Global	Brand General Manager	Reporting access
GG-<Brand>-ITAdmins	Global	Brand IT admin accounts	Receives delegated rights on the brand OU only
GG-HQ-ITAdmins (Tier 0)	Global	Group IT admins	Member of Domain Admins (very few people)
DL-Share-<Brand>-RW / -R	Domain local	GG groups	NTFS permission on shares

Script 2 - Create groups and an AGDLP example

```
$base = "DC=corp,DC=savorahg,DC=com"
# $brands = same hashtable used in ou.ps1

foreach ($b in $brands.Keys) {
    $code = $brands[$b].Code
    $mgmt = "OU=Management,OU=$b,OU=Brands,$base"

    # Brand-level role groups (Global)
    foreach ($g in "GM","ITAdmins","Managers") {
        New-ADGroup -Name "GG-$code-$g" -GroupScope Global -GroupCategory Security -Path $mgmt
    }

    # Branch staff groups (Global)
    foreach ($br in $brands[$b].Branches.Keys) {
        $bc = $brands[$b].Branches[$br]
        New-ADGroup -Name "GG-$code-$bc-Staff" -GroupScope Global -GroupCategory Security `
            -Path "OU=Groups,OU=$br,OU=$b,OU=Brands,$base"
    }
}

# AGDLP example: accounts -> Global group -> Domain Local group -> permission on share
```

```
New-ADGroup -Name "DL-Share-CasaFuego-RW" -GroupScope DomainLocal -GroupCategory Security `
    -Path "OU=Groups,OU=HQ-Corporate,$base"
Add-ADGroupMember -Identity "DL-Share-CasaFuego-RW" -Members "GG-CF-Managers"
```

4.5 Delegation Model

Delegation lets each brand manage itself without being a Domain Admin.

Role	Scope	Allowed	Not allowed
Group IT (Tier 0)	Entire domain	Full administration, GPO, DCs	Daily email / browsing with admin account
Brand IT Admin	Own Brand OU only	Reset passwords, unlock accounts, create/join computers, manage branch groups	Touch other brands, DCs, GPO links, privileged groups
Branch Manager	Own branch (via group)	Access branch share; request changes	Any AD administration
Staff	Own account	Sign in, access assigned shares	Local admin rights

Script 3 - Delegation for Casa Fuego IT admins

```
# Easiest method: right-click the Brand OU > Delegate Control (wizard).
# Command-line equivalent (example for Casa Fuego IT admins):
$ou = "OU=CasaFuego,OU=Brands,DC=corp,DC=savorahg,DC=com"

dsacls $ou /I:S /G "SAVORA\GG-CF-ITAdmins:CA;Reset Password;user"
dsacls $ou /I:S /G "SAVORA\GG-CF-ITAdmins:WP;lockoutTime;user"
dsacls $ou /I:S /G "SAVORA\GG-CF-ITAdmins:CC;computer"

# Test: log in as a CasaFuego IT admin and try to reset a SakuraBay user.
# Expected result: Access denied.
```

4.6 Administrative Tier Model

Tier	Assets	Rule
Tier 0	Domain controllers, AD, krbtgt, Domain/Enterprise Admins	Tier 0 accounts sign in ONLY to DCs / PAWs. Denied on all other machines by GPO.
Tier 1	Servers (FS01, application servers)	Server admins never sign in to workstations.
Tier 2	Workstations and POS terminals, user accounts	Brand IT Admins operate here only.

Why it matters for Kerberos: if a Tier 0 account signs in to a workstation, its TGT and keys can be stolen from that machine. Tiering prevents credential theft from reaching the top of the domain.

4.7 Sites, Subnets and Replication

Site	Subnet(s)	Notes
HQ-Site	10.10.1.0/24	Contains DC01, DC02, FS01 and lab clients
Casa Fuego branches	10.10.11.0/24, 10.10.12.0/24, 10.10.13.0/24	Makati, BGC, Quezon City (logical sites)
Sakura Bay branches	10.10.21.0/24, 10.10.22.0/24, 10.10.23.0/24	Ortigas, Alabang, Cebu
Trattoria Bella branches	10.10.31.0/24, 10.10.32.0/24, 10.10.33.0/24	Greenhills, Eastwood, Davao
Golden Wok branches	10.10.41.0/24, 10.10.42.0/24, 10.10.43.0/24	Binondo, Pasay, Baguio

In the lab only HQ-Site contains domain controllers; branch sites are created to practice subnet-to-site mapping and client site selection. An optional advanced exercise is to add a Read-Only Domain Controller (RODC) for one branch.

Script 4 - Sites and subnets

```
# HQ site and subnet
New-ADReplicationSite -Name "HQ-Site"
New-ADReplicationSubnet -Name "10.10.1.0/24" -Site "HQ-Site"
Get-ADDomainController -Filter * | ForEach-Object {
    Move-ADDirectoryServer -Identity $_.Name -Site "HQ-Site"
}

# Example branch site (repeat for the other 11 branches)
New-ADReplicationSite -Name "CF-Makati"
New-ADReplicationSubnet -Name "10.10.11.0/24" -Site "CF-Makati"
```

4.8 DNS, DHCP and FSMO Roles

- **DNS:** Active Directory-integrated zones on DC01 and DC02. All members use the DCs as DNS servers. Kerberos and domain join depend on correct DNS (SRV records).
- **DHCP:** Installed on DC01 or FS01 with one scope for HQ-Site (10.10.1.100 - 10.10.1.199). Optional: a second scope for each branch subnet.
- **FSMO roles:** All five roles on DC01 initially. The PDC Emulator is also the forest time source (NTP). Practice transferring roles to DC02 and seizing them in a failure test.
- **Global Catalog:** Enabled on both DCs.

5. Architecture Diagrams

Figures 1 to 3 are the main portfolio diagrams: the logical AD design, the VM lab topology and the Kerberos flow.

Figure 1 - Logical AD Design: Savora Hospitality Group (Single Forest / Single Domain)

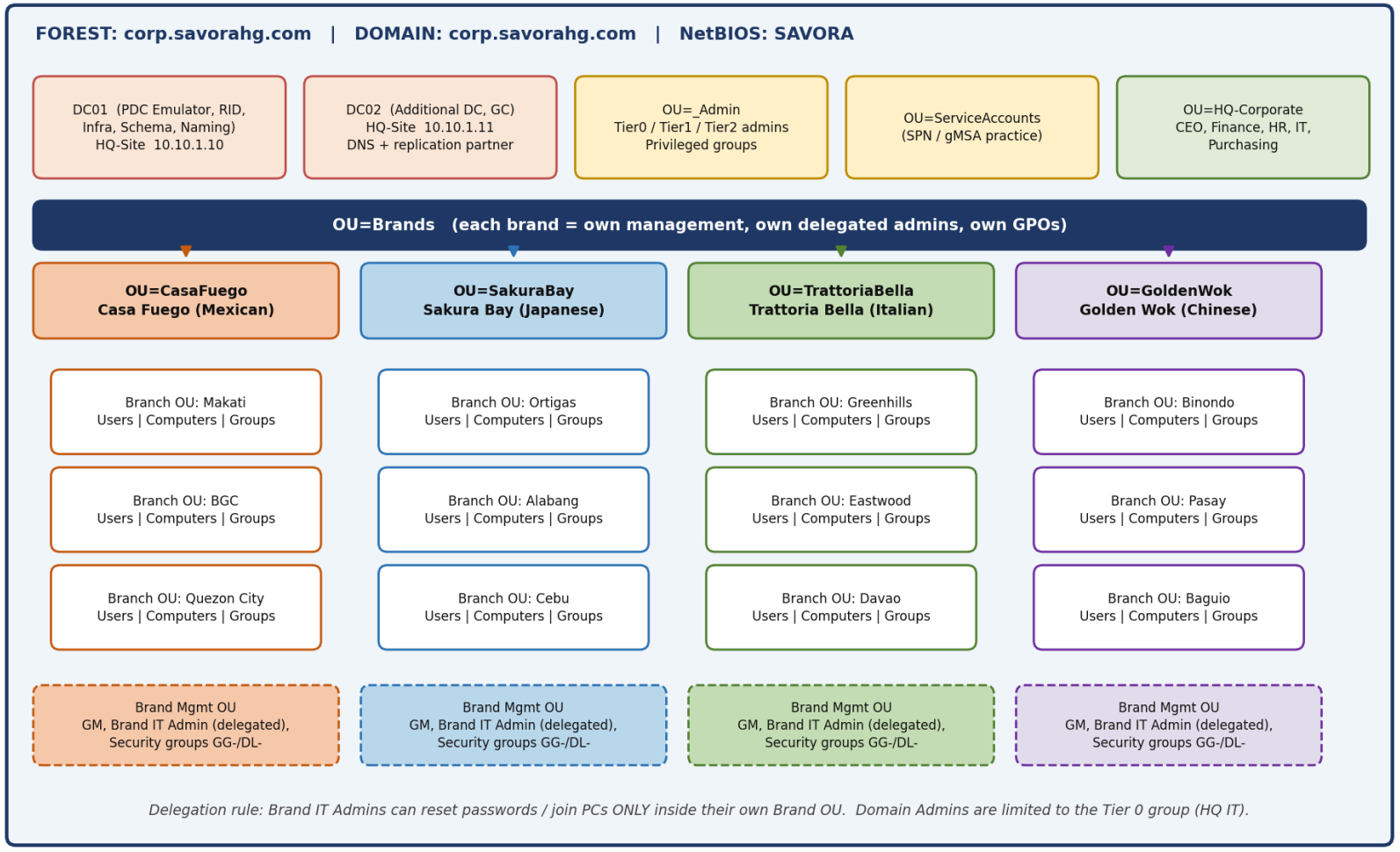
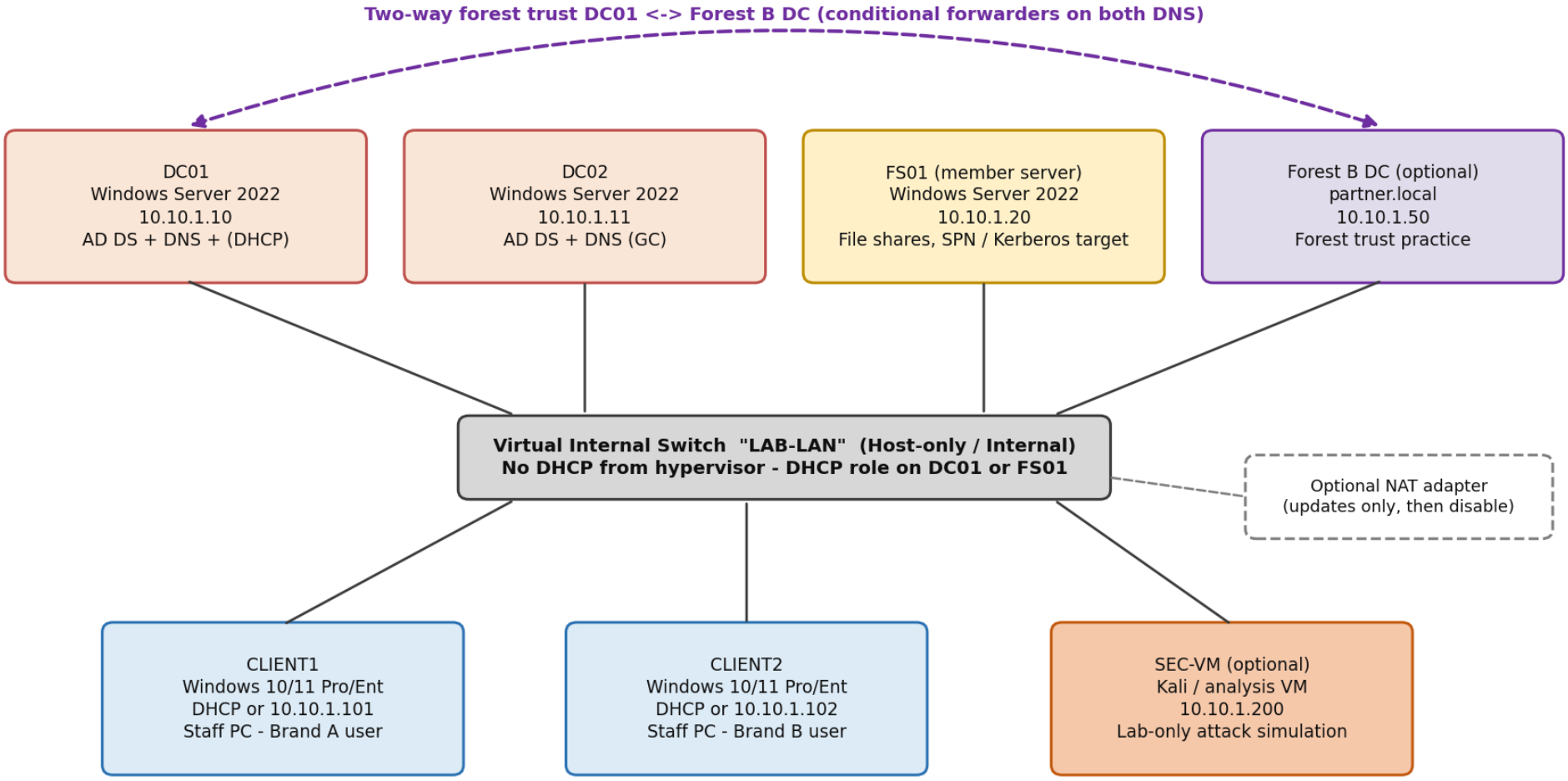


Figure 1 - Logical AD design: one forest, one domain, delegated brand OUs

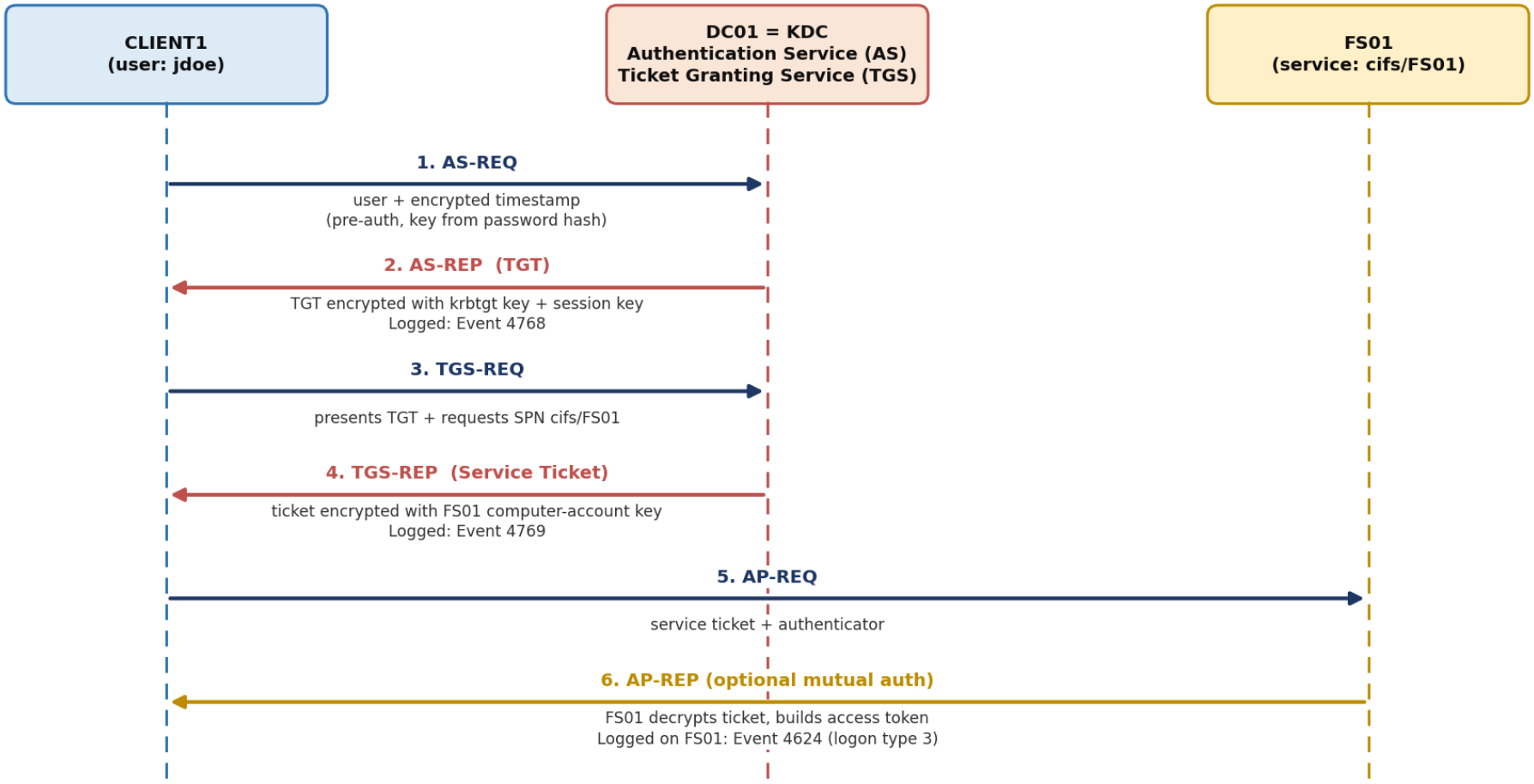
Figure 2 - VM Lab Topology (Internal Network 10.10.1.0/24)



Logical sites (Sites and Services): HQ-Site 10.10.1.0/24; branch subnets 10.10.11-13, 21-23, 31-33, 41-43 /24 are defined for practice.

Figure 2 - VM lab topology and optional forest trust

Figure 3 - Kerberos Authentication Flow (user jdoe opens \\FS01\Share)



Key ideas: password never crosses the wire | KDC never talks to the service | clocks must be within 5 minutes | krbtgt hash protects every TGT

Figure 3 - Kerberos authentication flow (AS, TGS and AP exchanges)

6. Technical Requirements (Lab Build)

6.1 Host Machine

Resource	Minimum	Recommended
CPU	4 cores with virtualization (VT-x / AMD-V) enabled in BIOS	6-8 cores
RAM	16 GB (run DC01, FS01, CLIENT1, CLIENT2 only)	32 GB (all VMs, including DC02 and Forest B)
Storage	250 GB free	500 GB SSD (thin-provisioned disks)
Hypervisor	VirtualBox, VMware Workstation, or Hyper-V	Any one of these; use snapshots

6.2 Virtual Machines

VM	OS	vCPU	RAM	Disk	IP address	Role
DC01	Windows Server 2022 (or 2025) Eval	2	4 GB	60 GB	10.10.1.10	First DC, DNS, FSMO, DHCP
DC02	Windows Server 2022 Eval (Core optional)	2	2-4 GB	60 GB	10.10.1.11	Additional DC, DNS, GC
FS01	Windows Server 2022 Eval	2	4 GB	80 GB	10.10.1.20	File server, Kerberos service target
CLIENT1	Windows 10/11 Pro or Enterprise Eval	2	4 GB	60 GB	DHCP / .101	Brand A staff PC
CLIENT2	Windows 10/11 Pro or Enterprise Eval	2	4 GB	60 GB	DHCP / .102	Brand B staff PC
FORESTB-DC (optional)	Windows Server 2022 Eval	2	4 GB	60 GB	10.10.1.50	partner.local forest for trust lab
SEC-VM (optional)	Kali or analysis VM	2	4 GB	40 GB	10.10.1.200	Attack simulation, isolated lab only

6.3 Software and Media

- Windows Server 2022 (or 2025) evaluation ISO from the Microsoft Evaluation Center (180 days).
- Windows 10 / 11 Enterprise evaluation ISO (90 days) or a licensed Pro edition.
- RSAT tools (Active Directory Users and Computers, Group Policy Management, DNS, Sites and Services) on DC01 or a client.
- Optional: Wireshark (to observe Kerberos on UDP/TCP 88), Sysinternals, a text editor for scripts.

6.4 Network Requirements

- All lab VMs on one **internal / host-only virtual switch**. No bridging to a real network.
- Static IPs for servers. Clients use DHCP or static IPs with **DNS pointing only to the DCs**.
- An optional NAT adapter may be enabled temporarily for Windows updates, then disabled.

- Required ports between clients and DCs: DNS 53, **Kerberos 88**, LDAP 389/636, SMB 445, Kerberos password change 464, RPC 135 and dynamic ports, Global Catalog 3268/3269.
- Time: DC01 (PDC emulator) is the authoritative time source; all members sync to the domain. Skew must stay under **5 minutes**.

7. Security Requirements

7.1 Password and Lockout Policy

Account type	Min length	Lockout	Notes
Standard staff (Default Domain Policy)	12	5 attempts / 15 min	Complexity on; block common passwords where possible; history 24
Privileged / admin accounts (Fine-Grained PSO)	16	3 attempts / 30 min	Applied to GG-HQ-ITAdmins and brand IT admin groups
Service accounts (Fine-Grained PSO)	30 or gMSA	n/a	Prefer gMSA so the password is managed and rotated automatically

7.2 Kerberos Requirements

Kerberos is the primary authentication protocol in AD. The requirements below turn the protocol into concrete settings you can configure, observe and test.

ID	Requirement	How to implement / verify
KR-01	Time synchronization within 5 minutes	PDC emulator as NTP source; `w32tm /query /status`; test by skewing a client clock and observing KRB_AP_ERR_SKEW
KR-02	Default ticket lifetimes documented and reviewed (TGT 10 h, renewal 7 days, service ticket 600 min)	Default Domain Policy > Kerberos Policy; observe with `klist`
KR-03	Pre-authentication required on all accounts	Query accounts with DoesNotRequirePreAuth (Script 8); expect zero results
KR-04	AES encryption preferred; RC4 disabled after compatibility testing	GPO: Network security: Configure encryption types allowed for Kerberos; audit with Event 4769 (ticket encryption type 0x17 = RC4)
KR-05	SPNs inventoried; no unnecessary user accounts with SPNs	`setspn -L`, Script 8 query; convert to gMSA where possible
KR-06	No unconstrained delegation except DCs; use constrained / resource-based delegation	Script 8 query; set 'Account is sensitive and cannot be delegated' on admins
KR-07	Privileged users placed in the Protected Users group	Verify no RC4, no NTLM, no delegation, 4-hour TGT for those users
KR-08	krbtgt password rotated twice (with replication wait between resets)	Documented procedure; test in lab and note that existing TGTs become invalid
KR-09	Kerberos events collected and reviewed	Events 4768, 4769, 4771 on DCs; see Section 7.4
KR-10	DNS SRV records healthy (_kerberos._tcp, _ldap._tcp)	`dcdiag /test:dns`, `nslookup -type=SRV _kerberos._tcp.corp.savorahg.com`

Script 8 - Kerberos hygiene and inspection commands

```
# --- Defensive audit queries (run on a DC or admin workstation) ---
```

```
# 1) Accounts that do NOT require Kerberos pre-authentication (AS-REP roasting risk)
Get-ADUser -Filter 'DoesNotRequirePreAuth -eq $true' -Properties DoesNotRequirePreAuth |
    Select-Object Name, SamAccountName

# 2) User accounts that own SPNs (Kerberoasting exposure)
Get-ADUser -Filter 'ServicePrincipalName -like "*"' -Properties ServicePrincipalName |
    Select-Object Name, ServicePrincipalName

# 3) Computers trusted for unconstrained delegation (should only be DCs)
Get-ADComputer -Filter 'TrustedForDelegation -eq $true' | Select-Object Name

# 4) Force AES on an account and protect an admin
Set-ADUser svc-backup -KerberosEncryptionType AES256
Add-ADGroupMember -Identity "Protected Users" -Members adm-jdoe

# 5) Client-side ticket inspection
klist            # list cached tickets (look for krbtgt/CORP.SAVORAHG.COM and cifs/FS01)
klist purge      # clear tickets, then reopen \\FS01\Share and run klist again
setspn -L FS01   # list SPNs registered to FS01
w32tm /query /status   # confirm time sync (Kerberos tolerance = 5 minutes)
```

7.3 Hardening Baseline

- Windows Firewall enabled on all profiles; only required ports opened.
- Disable SMBv1; require **SMB signing**; require **LDAP signing** and channel binding on DCs.
- Restrict NTLM: audit first, then deny where Kerberos works (NTLM relay and pass-the-hash resistance).
- Disable the Print Spooler service on domain controllers.
- Deploy **Windows LAPS** so every workstation and server has a unique, rotating local administrator password stored in AD.
- Remove users from local Administrators; deny interactive logon of Tier 0 accounts on Tier 1/2 machines.
- Enable BitLocker, Credential Guard (where supported) and automatic Windows Updates on clients.
- Create accounts for admins separate from daily accounts; never use Domain Admin for email or browsing.
- Protect OUs from accidental deletion; enable the AD Recycle Bin.

7.4 Auditing and Logging

Enable Advanced Audit Policy by GPO on domain controllers and members. Increase the Security log size (at least 1 GB on DCs) and forward logs where possible.

Event ID	Meaning	Why it matters
4768	Kerberos TGT requested (AS-REQ)	Successful and failed logons; pre-auth type; AS-REP roasting indicators
4769	Kerberos service ticket requested (TGS-REQ)	Kerberoasting (many requests, RC4 0x17); service access trace
4771	Kerberos pre-authentication failed	Wrong passwords, password spraying
4776	NTLM credential validation	Shows NTLM use that should be Kerberos
4624 / 4625	Logon success / failure	Logon types, source IP, lateral movement
4672	Special privileges assigned to new logon	Administrator sign-ins
4720, 4722, 4724, 4725, 4726, 4738	User created, enabled, password reset, disabled, deleted, changed	Joiner / mover / leaver audit

Event ID	Meaning	Why it matters
4728, 4732, 4756	Member added to global / local / universal group	Privilege escalation through group change
4740	Account locked out	Brute force or password spraying
4662, 5136	Directory object operation / modified	DCSync (replication rights) and AD object tampering
1102	Audit log cleared	Attacker covering tracks

7.5 Kerberos Attack and Defense Lab

> **Safety rule:** Perform simulations only on your own isolated lab VMs with fictional data. The goal is to understand the technique, capture the evidence the DC logs, and prove the mitigation works. Record each exercise as detection engineering notes in the portfolio.

Technique	What it abuses	Detection	Mitigation
Kerberoasting	Any user can request a service ticket for an SPN; ticket is encrypted with the service account password	Many 4769 events from one user, RC4 (0x17), unusual SPNs	gMSA / 30+ char passwords, AES only, remove unused SPNs
AS-REP roasting	Accounts without pre-authentication return crackable data	4768 with pre-auth type 0 for user accounts	Require pre-auth on all accounts (KR-03)
Pass-the-ticket	Stolen TGT / service ticket reused from another machine	Same account from unexpected host / IP; 4624 anomalies	Tiering, Credential Guard, Protected Users, short lifetimes
Golden ticket	Forged TGT using the krbtgt key	Service tickets (4769) with no prior 4768; abnormal ticket lifetime	Protect DCs, rotate krbtgt twice, monitor replication rights
Silver ticket	Forged service ticket using a service account key	Access to service with no matching 4769 on DC	gMSA, strong service secrets, PAC validation
Unconstrained delegation abuse	Server caches users' TGTs	Computers/users flagged TrustedForDelegation	Remove it; use constrained / RBCD; sensitive-account flag
DCSync	Replication permissions let an account copy password data	4662 with replication GUIDs from a non-DC	Limit 'Replicating Directory Changes' rights; alert
Password spraying	One password against many accounts	Many 4771 / 4625 across users from one source	Lockout policy, long passwords, MFA where available
NTLM relay / pass-the-hash	NTLM does not need the password, only the hash	4776 spikes; NTLM from servers	Restrict NTLM, SMB / LDAP signing, LAPS

8. Group Policy Plan

GPO	Linked to	Key settings
Default Domain Policy	Domain root	Password policy, account lockout, Kerberos policy (leave defaults documented)
SEC-Baseline-All	Domain root	Firewall on, SMB signing, NTLM audit/restrict, disable SMBv1, screen lock 10 min

GPO	Linked to	Key settings
DC-Hardening	Domain Controllers OU	Advanced audit policy, LDAP signing, Kerberos AES types, disable Print Spooler
WKS-Baseline	Brands OU (all brand computers)	Windows Update, local admin restriction, Windows LAPS, BitLocker, Defender
POS-Lockdown	POS computers (branch Computers OUs)	Block removable storage, restrict Control Panel, auto-logon kiosk shell where required
Brand drive maps	Each Brand OU	Map the brand share (e.g. \\FS01\Brands\CasaFuego) by group membership
Tier-Restrictions	Server / workstation OUs	Deny log on locally / via RDP for Tier 0 admin groups
Brand-Wallpaper	Each Brand OU	Brand-specific desktop background - proves per-brand policy

Rule: link GPOs to OUs, never edit the Default Domain Policy except for password, lockout and Kerberos settings. Test with `gpresult /r` and Group Policy Results.

9. File Server and Access Design

FS01 provides shares and acts as the Kerberos service target (SPN `cifs/FS01`). Permissions follow AGDLP.

Share path	Access	Permission group
\\FS01\Brands\CasaFuego\<Branch>	Branch staff read/write own branch	DL-Share-CasaFuego-<Branch>-RW <- GG-CF-<Branch>-Staff
\\FS01\Brands\CasaFuego\Management	Brand managers and GM	DL-Share-CasaFuego-Mgmt-RW <- GG-CF-Managers, GG-CF-GM
\\FS01\HQ\Finance	Finance only	DL-Share-HQ-Finance-RW <- GG-HQ-Finance
\\FS01\Public	All employees read-only	DL-Share-Public-R <- Domain Users

Repeat the Brands pattern for the other three brands. Test that a Sakura Bay user cannot open a Casa Fuego branch folder.

10. Implementation Plan

Take a snapshot of every VM at the end of each phase so you can roll back and so you have clean evidence for screenshots.

Phase	Tasks	Validation / evidence
0. Preparation	Install hypervisor; create the internal switch; download ISOs; create VM templates	Screenshot of VM list and virtual network
1. DC01 and forest	Install Server; static IP; rename; install AD DS and DNS; promote new forest (Script: forest)	`dcdiag`, DNS zones, screenshot of ADUC
2. AD structure	Create OUs, groups, bulk users from CSV, enable Recycle Bin (Scripts 1, 2, users)	OU tree screenshot; user count report

Phase	Tasks	Validation / evidence
3. DC02 and replication	Join DC02, promote as additional DC (Script: dc02); enable GC	`repadmin /replsummary`; create user on DC01 and see it on DC02
4. Sites and subnets	Create HQ and branch sites and subnets (Script 4)	Sites and Services screenshot
5. Clients	Install CLIENT1 / CLIENT2; DNS to DCs; join domain; move to branch OUs (Script: join)	Domain sign-in screenshots; `klist` output
6. File server	Build FS01; shares; AGDLP permissions; drive maps	Access allowed / denied tests
7. Delegation	Delegate control per Brand OU (Script 3)	Brand admin resets own user OK; other brand denied
8. Group Policy	Create and link GPOs from Section 8	`gpresult` and wallpaper / lockdown proof
9. Security hardening	Fine-grained password policies, LAPS, Protected Users, AES, tiering, SMB / LDAP signing	Policy results; hardening checklist
10. Auditing	Advanced audit policy; log size; collect Section 7.4 events	Event Viewer screenshots for 4768 / 4769 / 4771
11. Kerberos lab	Trace the flow with klist and Wireshark; run the attack / defense exercises in Section 7.5	Written findings per technique
12. Backup and DR	Windows Server Backup system state; test authoritative restore; FSMO transfer and seizure	Restore evidence
13. Forest trust (optional)	Build Forest B DC; conditional forwarders; forest trust (Script: trust)	`nltest /domain_trusts`; cross-forest access test
14. Documentation	Write the final report, publish scripts and diagrams	Completed portfolio

Script 5 - Build DC01 and create the forest

```
# --- Run on DC01 (elevated PowerShell) ---
Rename-Computer -NewName "DC01" -Restart          # reboot, then continue

New-NetIPAddress -InterfaceAlias "Ethernet" -IPAddress 10.10.1.10 -PrefixLength 24
Set-DnsClientServerAddress -InterfaceAlias "Ethernet" -ServerAddresses 10.10.1.10

Install-WindowsFeature AD-Domain-Services -IncludeManagementTools

Install-ADDSForest `
  -DomainName "corp.savorahg.com" `
  -DomainNetbiosName "SAVORA" `
  -ForestMode WinThreshold -DomainMode WinThreshold `
  -InstallDns `
  -SafeModeAdministratorPassword (Read-Host -AsSecureString "DSRM password") `
  -Force
```

Script 6 - Promote DC02 as an additional domain controller

```
# --- Run on DC02 (static IP 10.10.1.11, DNS = 10.10.1.10) ---
Install-WindowsFeature AD-Domain-Services -IncludeManagementTools

Install-ADDSDomainController `
  -DomainName "corp.savorahg.com" `
  -Credential (Get-Credential SAVORA\Administrator) `
  -InstallDns -SiteName "HQ-Site" `
  -SafeModeAdministratorPassword (Read-Host -AsSecureString "DSRM password") `
  -Force

# After reboot, point DC02's DNS at itself and DC01, then verify:
repadmin /replsummary
dcdiag /v
```

Script 7 - Bulk-create users from CSV

```
# users.csv  (header + sample rows)
# FirstName,LastName,Username,Brand,Branch,Title
# Maria,Santos,msantos,CasaFuego,Makati,Branch Manager
# Jose,Reyes,jreyes,CasaFuego,Makati,Cashier
# Ana,Cruz,acruz,SakuraBay,Ortigas,Kitchen Staff

$base = "DC=corp,DC=savorahg,DC=com"
$pw   = Read-Host -AsSecureString "Initial password for new users"

Import-Csv .\users.csv | ForEach-Object {
    $ou = "OU=Users,OU=$($_.Branch),OU=$($_.Brand),OU=Brands,$base"
    New-ADUser `
        -Name "$($_.FirstName) $($_.LastName)" `
        -GivenName $_.FirstName -Surname $_.LastName `
        -SamAccountName $_.Username `
        -UserPrincipalName "$($_.Username)@corp.savorahg.com" `
        -Title $_.Title -Company $_.Brand -Department $_.Branch `
        -Path $ou -AccountPassword $pw `
        -ChangePasswordAtLogon $true -Enabled $true
}
```

Script 9 - Join a client to the domain

```
# --- Run on CLIENT1 / CLIENT2 (DNS must point to 10.10.1.10) ---
Set-DnsClientServerAddress -InterfaceAlias "Ethernet" -ServerAddresses 10.10.1.10,10.10.1.11
Add-Computer -DomainName "corp.savorahg.com" -Credential SAVORA\Administrator -Restart
# Afterwards, move the computer object into its branch Computers OU.
```

Script 10 - Optional forest trust preparation (DNS and verification)

```
# On DC01: forward partner.local queries to Forest B DC
Add-DnsServerConditionalForwarderZone -Name "partner.local" -MasterServers 10.10.1.50 -ReplicationScope
"Forest"

# On the Forest B DC:
# Add-DnsServerConditionalForwarderZone -Name "corp.savorahg.com" -MasterServers 10.10.1.10
-ReplicationScope "Forest"

nslookup partner.local          # must return 10.10.1.50
netdom trust corp.savorahg.com /domain:partner.local /verify
nltest /domain_trusts
```

11. Test and Validation Plan

Test	Requirement	Steps	Expected result
TC-01	BR-01	Sign in to CLIENT1 with a domain user	Success; `whoami` shows SAVORA\user
TC-02	BR-07	Create a user on DC01, check DC02; shut down DC01 and sign in	User replicates; sign-in works through DC02
TC-03	BR-02	Brand IT admin of Casa Fuego resets a Casa Fuego user, then a Sakura Bay user	First succeeds; second is denied
TC-04	BR-05	Wrong password 5 times on a staff account	Account locks; Event 4740 logged
TC-05	BR-04 / KR-02	On CLIENT1 run `klist purge`, open \\FS01\Share, run `klist`	TGT for krbtgt and service ticket for cifs/FS01 shown
TC-06	BR-06	Sign in and open a share; review DC log	Events 4768 and 4769 recorded; 4624 on FS01
TC-07	KR-01	Set CLIENT1 clock 10 minutes ahead and sign in	Kerberos fails (clock skew); restore time and retest
TC-08	BR-05	Run `gpresult /r` on a Casa Fuego PC and a Golden Wok PC	Each shows its own brand GPOs

Test	Requirement	Steps	Expected result
TC-09	KR-03 / KR-05 / KR-06	Run Script 8 queries	No accounts without pre-auth; SPN and delegation lists reviewed
TC-10	KR-07	Add admin to Protected Users and inspect ticket	TGT lifetime 4 hours; NTLM and RC4 unavailable for the account
TC-11	BR-10	Back up system state, delete a test OU, restore	Object restored
TC-12	BR-09	Create forest trust and access a resource using a Forest B account	Cross-forest access works; selective authentication behaves as configured

12. Portfolio Deliverables

- This requirements document (PDF and DOCX) and the three diagrams.
- Screenshots from each phase (Section 10) with a short caption explaining what they prove.
- All PowerShell scripts in a public GitHub repository with a README (no real passwords or data).
- A **Kerberos write-up**: the six-step flow, annotated `klist` output, Wireshark capture and the matching 4768 / 4769 events.
- One page per attack technique (Section 7.5): how it works, evidence in logs, and how the mitigation stops it.
- A before / after hardening comparison and the completed test plan with pass / fail results.
- A lessons-learned section and a list of possible next steps (Entra ID hybrid, SIEM forwarding, Microsoft Defender for Identity).

13. Risks and Assumptions

Risk	Impact	Mitigation
Host runs out of RAM	VMs slow or crash	Run minimum set; use Server Core for DC02; dynamic memory
Evaluation licenses expire	Lab stops after 180 / 90 days	Keep scripts; rebuild quickly; rearm where allowed
DNS misconfiguration	Domain join and Kerberos fail	Point all VMs to DC DNS only; run `dcdiag /test:dns`
Cloned VMs with duplicate SIDs	Replication or trust problems	Install from clean ISO or sysprepped template
Attack tools affecting real network	Policy / legal issue	Internal-only switch; disable NAT during exercises; only attack your own VMs
Snapshot rollback of a DC after replication	USN rollback / lingering objects	Use snapshots carefully with multiple DCs; restore both DCs together

14. Approval

Role	Name	Signature	Date
Chairman / CEO (requester)			

Role	Name	Signature	Date
IT Engineer (author)	jayarzuniga		October 16, 2026

Appendix A - Command Cheat Sheet

Command	Use
`dcdiag /v`	Full health check of a domain controller
`repadmin /replsummary` / `repadmin /showrepl`	Replication status and errors
`nltest /dsgetdc:corp.savorahg.com`	Which DC a client is using
`nltest /domain_trusts`	List trusts
`netdom query fsmo`	Show FSMO role holders
`klist`, `klist purge`, `klist tgt`	View / clear Kerberos tickets
`setspn -L <account>` / `setspn -Q cifs/FS01`	List / find SPNs
`gpresult /r`, `gpupdate /force`	Group Policy results and refresh
`w32tm /query /status`	Time sync status
`Get-ADUser -Filter * -SearchBase "OU=CasaFuego,OU=Brands,DC=corp,DC=savorahg,DC=com"`	List users in one brand

Appendix B - Glossary

Term	Meaning
KDC	Key Distribution Center; runs on every DC; contains the Authentication Service and Ticket Granting Service.
TGT	Ticket Granting Ticket; proves the user already authenticated; encrypted with the krbtgt key.
Service ticket (TGS)	Ticket for one specific service, encrypted with that service account's key.
SPN	Service Principal Name that identifies a service instance (example: cifs/FS01).
krbtgt	Built-in account whose key protects all TGTs; compromise means domain compromise.
FSMO	Flexible Single Master Operations; five special DC roles (Schema, Domain Naming, PDC Emulator, RID, Infrastructure).
AGDLP	Accounts - Global - Domain Local - Permissions group nesting model.
GPO	Group Policy Object; centrally enforced settings linked to sites, domains or OUs.
gMSA	Group Managed Service Account; AD manages and rotates the password automatically.
RODC	Read-Only Domain Controller, used in low-security branch locations.